BYOD POLICY

COMM2700
CALLAHAN O'QUINN

1. Compliance & Risk Assessment

A. Laws & Regulations

The following laws & regulations should be considered when writing a BYOD policy in Nova Scotia:

- **NIST Cybersecurity Framework:** NIST, the National Institute of Standards and Technology is a U.S. federal agency that sets the standards for handling information and maximizing cybersecurity. Following the NIST framework is a best practice for any organization's tech implementation. Some relevant NIST protocols surrounding BYOD are:
    - **NIST Cybersecurity Framework (CSF):** General cybersecurity practices that encourage risk assessment, access control and monitoring for BYOD.
    - **NIST Special Publication 1800-22:** Specific guidelines for BYOD security. It outlines the commercially available products organizations can use for BYOD security, including best practices for specific Operating Systems & devices.
    - **NIST Special Publication (SP) 800-124 Rev. 2:** A guideline for handling mobile devices in the workplace, including those brought from home. It recommends security policies, encryption and device management solutions.
    - **NIST SP 800-46 Rev. 2:** This protocol specifically pertains to remote access and BYOD security. It covers VPN usage, endpoint security and risk management for personal devices.
    - **NIST SP 800-171:** Details on security requirements for handling sensitive information for organizations, including BYOD policies.

- **PIPEDA:** The Personal Information Protection and Electronic Documents Act is a federal law that enforces the proper use of sensitive information in Canada. It states that:
    - **Consent is mandatory for collecting personal information.**
    - **Organizations must have an appropriate level of security for personal data on personal devices.**
    - **Personal data must be accessible if requested by authorities.**

- **Criminal Code of Canada – Section 342.1:** This section of the Criminal Code of Canada pertains to the unauthorized use of computers. It states that:
    - **Unauthorized access to client or corporate data from an employee's personal device is forbidden.**
    - **BYOD policies must be implemented to prevent data breaches and external attacks.**

- **PIIDPA:** The Nova Scotia Personal Information International Disclosure Protection Act is a provincial law that states:
    - **The storage and access of personal data outside Canada (including data stored on personal devices) is restricted.**
    - **Data stored on BYOD devices must remain within Canada unless an exception is made.**

- **Digital Privacy Act:** A 2015 amendment to PIPEDA that provides stronger privacy protection for Canadian citizens. It requires that **if personal information is compromised on an employee's device, the breach must be reported**.

B. Potential Security Risks

1. **Data Leaks:**

   Data leakage is one of the most common security risks for any organization. Regarding BYOD, leaks can occur from misplaced/stolen devices, malware on a personal device or improper implementation and/or adherence to data security policies. A data leak could result in the organization facing lawsuits and fines, that accompanied with the production loss and remediation can cost an organization a lot of money. Ponemon Institute's reported in 2023 that the average cost of a data breach was $4.45 million USD. Legal penalties, the production halt and damage to the company's reputation also make the recovery from a leak extremely difficult.

2. **Malicious Software**

   Many devices that are infected with malicious software go completely unrecognized, and due to the monitoring limitations, BYOD can be difficult to defend against infection. There is also a rise in malicious apps that mimic the appearance of common apps on the google play store that can infect an employee's android device. If an infected device connects to an organizations network and/or has access to its sensitive information, major security risks can occur, such as:

   - The malware spreading across the network to other devices

- Data being breached
- Harmful malware such as trojans or key-loggers compromising systems
- Undetected surveillance
- Ransom attacks

3. **Mixing of Personal and Business Usage**

   It is rare that an employee's device will be solely used for work if it is BYOD. Therefore, what an employee does on their device for personal use is up to their discretion. An employee could connect to a potentially dangerous public network/websites or share the device with someone who is not a member of the organization. While not inherently dangerous, this mixing of activities on one device can lead to leaks or malicious activity.

4. **Governance of Devices**

   Under a BYOD policy, the employee is the owner of the device, which extremely limits the amount of control the organization has over it. While policies and security training can help an employee use their device safely, there is no guarantee on how well they will adhere to this. Another concern with this is if an employee wants to act maliciously against the organization, the organizations would be limited in their defense as the device is the employee's property and only so much access can be controlled remotely.

2. Key Policy Components

A. Device Eligibility

In most circumstances, I would recommend smartphones to be excluded from a BYOD policy. Smartphones present a particularly high risk in terms of lack of governance & mixing of personal/business use due to the nature of those devices. However, for this line of business and their specific mention of conveniency, I think it's best to allow them (with stricter limitations (to be covered in the next section)).

This is the list of devices that I would allow for the BYOD policy:

- **Laptops:**
  - **MacBook air & pro**
  - **Laptops capable of running Windows 11+ (at date of creating the policy)**
  - **Laptops capable of running Ubuntu Linux**
- **Tablets:**
  - **Apple iPad**

    - **Samsung Galaxy S Tablets**
- **Smartphones:**
    - **Apple iPhone**
    - **Android OS smartphones**

It is hard to be too strict about make/model of devices for BYOD, as it kind of goes against the nature of it. Rather than be strict about makes, I would focus on Operating Systems. OS eligibility couldn't be static due to how rapid new OS versions, updates and the discontinuing of support occurs. Therefore, devices would have to be assessed & approved prior to BYOD based on their current OS and age of the device. I would draft a BYOD request form for the employee to fill with all that relevant information, which would be logged if/once approved.

The company would have to set a policy regarding updating devices, ensuring new updates have enough time to be community tested for bugs before allowing implementation for the BYOD devices. I would also recommend the company do a ~semi annually update to their OS and model eligibility to ensure that the approved BYOD devices continue to have adequate security support. I believe this is the best approach to accommodate for the wide array of personal devices employees may own.

B. Security Requirements, Access Control & Network Security

- **Security Requirements**
    - I would recommend the company implement an **endpoint management service** to help govern the BYOD devices. My recommendation would be **Microsoft Intune**; a cloud-based management solution that works on a very broad range of devices. Intune allows the organization to set policies & configurations for smartphones, tablets and computers that only apply to the work-related apps/services. Intune is cloud-based, meaning the organization would not have to invest in the hardware/software infrastructure themselves. It offers security features such as:
        - **Requiring a PIN to access work related apps**
        - **Restricting copying and pasting data outside of work apps**
        - **Encrypting data inside of work apps**
        - **Checking if the device meets security standards (ex. Updated OS's) before allowing access to work apps**
        - **Remote management of work apps; data can be wiped, and access can be revoked remotely.**
        - **Automatic VPN access for connected devices**

- The company should also implement a third-party **Intrusion Prevention System (IPS)**. An IPS detects, reports and blocks malicious activity as it occurs. It can cut communicate and block IP addresses the second suspicious activity is detected. My recommendation is **Cisco Secure IPS**. Cisco Secure IPS works with the broad category of devices eligible and works based on network. Therefore, it could be implemented to run on any device that connects to the required VPN. Cisco has been on the forefront of networking tools and hardware, so they are highly trusted for security purposes. Cisco Secure IPS has features such as:
    - **Threat detection with Talos (one of the largest threat intelligence services worldwide)**
    - **Packet inspection for encrypted packets (analyzes data as it is being sent/received despite its additional layers of security)**
    - **Automatic threat response to stop malicious activity before it can occur**
    - **Highly customizable configuration to meet the organizations security requirements**

- **Access Control**
    - Most general Access Control methods can be applied with MS Intune and Cisco Secure IPS. The Access Control methods I would implement for all devices would be:
        - **PINs for work applications**
        - **Mandatory VPN connection (with IPS services) to access work apps**
        - **A strong password policy for all work accounts (maybe a password management service that logs and creates strong passwords as well as enforces regular password updating)**
        - **Multi-factor authentication**
        - **Role-based access groups for designating certain functions and restrictions based on the employee's role and level of authority**
    - Access control specifically for laptops:
        - **Virtual Machine use where compatible**
        - **Separate profiles on the laptop specifically for work**
        - **Potentially the use of a physical "key" (ex. A USB drive with a token) required to access work related services**
        - **Software limitations set and implemented through Intune**
    - Access control specifically for tablets:
        - **Application limitations (enforced by Intune)**

        - **Private network connections only (limit the employee to only use work apps at home or in office by having them register their home network IP)**
    - Access control specifically for smartphones:
        - **Strict limitations on what apps and data can be accessed on smartphones. I would limit it to mail apps & a communication service such as MS teams.**
- **Network Security**
    - Most of the network security overlaps with what was previously mentioned. As BYOD will only be used with the VPN, the company's private network security will not be relevant for this policy. Using a VPN with the Cisco Secure IPS (or another strong IPS) should be adequate for the BYOD devices.

C. Acceptable Use

- **Prohibited Apps/Software**

  Only software required for work will be enabled through Intune. Laptops will have the most available software, tablets will have what is capable for them, and smartphones will have only what's necessary for convenience use.
- **Personal Use of Company Resources**

  MS Intune will ensure that company specific apps will only run across the VPN and will be monitored. The company should ensure that their contract upon hiring outlines that company data must never leave designated apps while using a BYOD device.
- **Data Handling & Storage**

  Company data usage will be secure with Intune, the VPN and IPS. If the company needs to revoke access to data, they can remotely use Intune. Data will be stored in the cloud and will be restricted from being downloaded to system storage as configured with Intune.

D. Monitoring & Compliance

- **Ethics**

With the division MS Intune creates, the company would not monitor anything on the devices that is not work related. Of course, the consideration of total device monitoring would arise, but where the device is the employee's property, as well as ethical concerns, I think it is not feasible. The apps and software approve for use would only be used for work purposes, therefore monitoring them should not be an issue from an ethical perspective. I'm

sure some would feel uncertain about any monitoring occurring on their device, but with the separation the VPN and Intune provide there would be a wall between work use and personal use.

- **Legality**

  PIPEDA is the law that would govern the monitoring of BYOD, while monitoring helps the company adhere to the other laws. Some key monitoring regulations under PIPEDA are:

  - **Consent must be granted from the employee to allow for monitoring**
  - **The company must outline their purpose for monitoring**
  - **Personal information gathered must only be appropriate for the organization**
  - **Monitoring should only be used to the degree deemed required**
  - **Employees must be aware of what is being monitored and what is done with the data**
  - **Data collected from monitoring must be secured appropriately**

References

Cavusoglu, H., Mishra, B., & Raghunathan, S. (2004). The effect of internet security breach announcements on market value: Capital market reactions for breached firms and internet security developers. *International Journal of Electronic Commerce, 9*(1), 69–104.

Cisco. (n.d.). *Cisco Secure IPS overview*. Cisco Systems. Retrieved April 6, 2025, from https://www.cisco.com/c/en_uk/products/security/ngips/index.html

Government of Canada. (1985). *Criminal Code, R.S.C., 1985, c. C-46, Section 342.1*. https://laws-lois.justice.gc.ca/eng/acts/C-46/page-81.html#h-117119

Government of Canada. (2000). *Personal Information Protection and Electronic Documents Act, S.C. 2000, c. 5*. https://laws-lois.justice.gc.ca/eng/acts/p-8.6/FullText.html

Government of Canada. (2015). *Digital Privacy Act (S.C. 2015, c. 32)*. https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/laws-amendments-to-pipeda/digital-privacy-act/

Government of Nova Scotia. (2006). *Personal Information International Disclosure Protection Act, S.N.S. 2006, c. 3*. https://nslegislature.ca/sites/default/files/legc/statutes/persinfo.htm

IBM Security. (2023). *Cost of a data breach report 2023*. Ponemon Institute. https://www.ibm.com/reports/data-breach

Microsoft. (n.d.). *Supported operating systems and browsers in Intune*. Microsoft Learn. Retrieved April 6, 2025, from https://learn.microsoft.com/en-us/mem/intune/fundamentals/supported-devices-browsers

Microsoft. (n.d.). *What is Microsoft Intune?*. Microsoft Learn. Retrieved April 6, 2025, from https://learn.microsoft.com/en-us/mem/intune/fundamentals/what-is-intune

Microsoft. (n.d.). *Windows device enrollment guide for Microsoft Intune*. Microsoft Learn. Retrieved April 6, 2025, from https://learn.microsoft.com/en-us/mem/intune/enrollment/windows-enrollment-methods#bring-your-own-device-byod

Microsoft. (n.d.). *Windows enrollment methods*. Microsoft Learn. Retrieved April 6, 2025, from https://learn.microsoft.com/en-us/mem/intune/enrollment/windows-enrollment-methods

National Institute of Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity (Version 1.1)* (NIST Cybersecurity Framework). https://doi.org/10.6028/NIST.CSWP.04162018

National Institute of Standards and Technology. (2020). *Protecting controlled unclassified information in nonfederal systems and organizations (Rev. 2)* (NIST Special Publication 800-171). https://doi.org/10.6028/NIST.SP.800-171r2

National Institute of Standards and Technology. (2021). *Mobile device security: Bring your own device (BYOD)* (NIST Special Publication 1800-22). https://www.nist.gov/publications/mobile-device-security-bring-your-own-device-byod

Scarfone, K., & Souppaya, M. (2009). *Guide to enterprise telework, remote access, and bring your own device (BYOD) security (Rev. 2)* (NIST Special Publication 800-46). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-46r2

Souppaya, M., & Scarfone, K. (2020). *Guidelines for managing the security of mobile devices in the enterprise (Rev. 2)* (NIST Special Publication 800-124). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-124r2

Yacono, L. (2024, September 12). *The 8 top BYOD security risks (and how to mitigate them)*. Cimcor Blog. https://www.cimcor.com/blog/7-scariest-byod-security-risks-how-to-mitigate

Note: ChatGPT was used primarily to help find specifics regarding legislation. Everything gathered from ChatGPT was cross-referenced with the source it provided.